

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

Annexure A

Scenario-Based

Code of Conduct:

I Atchaya Chandran R(192521394) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

R. Atchay

Question 1 (15 Marks)

1. Identification of Publicly Available Information & Tool Selection

To gather competitive intelligence passively for **ABC Technologies** without directly touching their live systems or triggering security alarms, specific open-source intelligence (OSINT) tools are applied:

- **Domain Registration Details:**
 - **Tool:** Whois / **Whois Lookup**
 - **Application:** Querying public domain registry databases (ARIN, RIPE, ICANN) using whois abctechnologies.com.
 - **Data Collected:** Registrant name, organization contact details, administrative/technical contacts, creation/expiration dates, and authoritative name servers.
- **Employee Email Addresses:**
 - **Tool:** TheHarvester / **Hunter.io**
 - **Application:** Executing theHarvester -d abctechnologies.com -b google, linkedin, hunter to aggregate publicly exposed emails from search engines and social platforms.
 - **Data Collected:** Standard email naming conventions (e.g., firstname.lastname@abctechnologies.com), active key personnel roles, and email addresses exposed in public filings or leaks.
- **Technology Stack:**
 - **Tool:** BuiltWith / **Wappalyzer**
 - **Application:** Inspecting publicly available web headers, client-side scripts, and domain analytics profiles.
 - **Data Collected:** Content Management Systems (CMS), web server versions, analytics engines, JavaScript frameworks, third-party APIs, and cloud hosting providers (e.g., AWS, Azure).
- **Publicly Exposed Subdomains:**
 - **Tool:** Sublist3r / **crt.sh (Certificate Search)**
 - **Application:** Querying search engine dorks and public SSL/TLS Certificate Transparency logs to discover subdomains (*.abctechnologies.com).
 - **Data Collected:** Discovery of target subdomains such as vpn.abctechnologies.com, dev.abctechnologies.com, mail.abctechnologies.com, and stage.abctechnologies.com.

2. Practical Application for Competitive Intelligence

Conducting passive footprinting allows security analysts and attackers to gather strategic insights about an organization:

[Public OSINT Data] ---> [Analytical Aggregation] ---> [Strategic Attack Surface Mapping]

(Whois, crt.sh, (Email formats, stack (Targeted Phishing, Unpatched

Wappalyzer) versions, dev servers) Software Vulnerabilities)

- **Attack Surface Mapping:** Subdomains like dev or test often run unpatched software or lack strict access controls, exposing entry points.
- **Social Engineering Preparation:** Uncovering active employee email formats and leadership names allows an adversary to craft highly targeted Spear-Phishing or Spear-Voice campaigns.
- **Vulnerability Target Identification:** Knowing the exact technology stack (e.g., an outdated web server version identified via BuiltWith) helps identify specific Common Vulnerabilities and Exposures (CVEs) without conducting noisy active port scans.

Topic 2: DNS Zone Transfers

Question 2 (15 Marks)

1. Application of DNS Tools for Zone Transfer Verification

To verify whether the target organization's primary or secondary DNS server allows unauthorized zone transfers (**AXFR requests**), the following commands can be executed:

Option A: Using dig (Domain Information Groper)

1. Find Authoritative Nameservers:

Bash

dig NS abctechologies.com +short

Output Example: ns1.abctechologies.com

1. Execute Zone Transfer Test:

Bash

dig @ns1.abctechologies.com abctechologies.com AXFR

Option B: Using nslookup

- 1. Start interactive session: nslookup
- 2. Specify server: server ns1.abctechologies.com
- 3. Query type: set type=any
- 4. Request transfer: ls -d abctechologies.com

2. Analysis of Retrieved DNS Records

If the DNS server is misconfigured (allowing queries from any IP address), a successful AXFR request returns the entire DNS zone file. The records are used during reconnaissance as follows:

DNS Record Type	Description & Information Gathered	Reconnaissance Value
A / AAAA Records	Maps domain/subdomain names directly to IPv4/IPv6 addresses.	Reveals the complete internal and external IP address layout of the enterprise network.
MX Records	Points to Mail Exchange servers (e.g., mail1.abctechologies.com).	Identifies email processing infrastructure, allowing targets to evaluate mail security gateways or direct mail server exploits.
CNAME Records	Canonical Name records mapping aliases to true domain names.	Discovers underlying cloud storage buckets (e.g., AWS S3 buckets), third-party services, and alias servers.
PTR Records	Pointer records for reverse DNS lookups.	Maps IP addresses back to domain names, helping expose internal naming conventions.
TXT Records	Human-readable text containing SPF, DKIM, or verification strings.	Reveals third-party cloud integrations and potential security enforcement gaps in email validation policies.

3. Reconnaissance Impact: Identifying Internal Assets

- **Internal Host Discovery:** Subdomains such as internal-portal.abctechologies.com or db-cluster.abctechologies.com expose sensitive infrastructure that is normally hidden from public search engines.
- **Network Topology Mapping:** The contiguous IP ranges discovered in A records enable precise targeting, eliminating the need to scan large, unrelated network blocks.

Topic 3: Introduction to Social Engineering – Attacks & Countermeasures

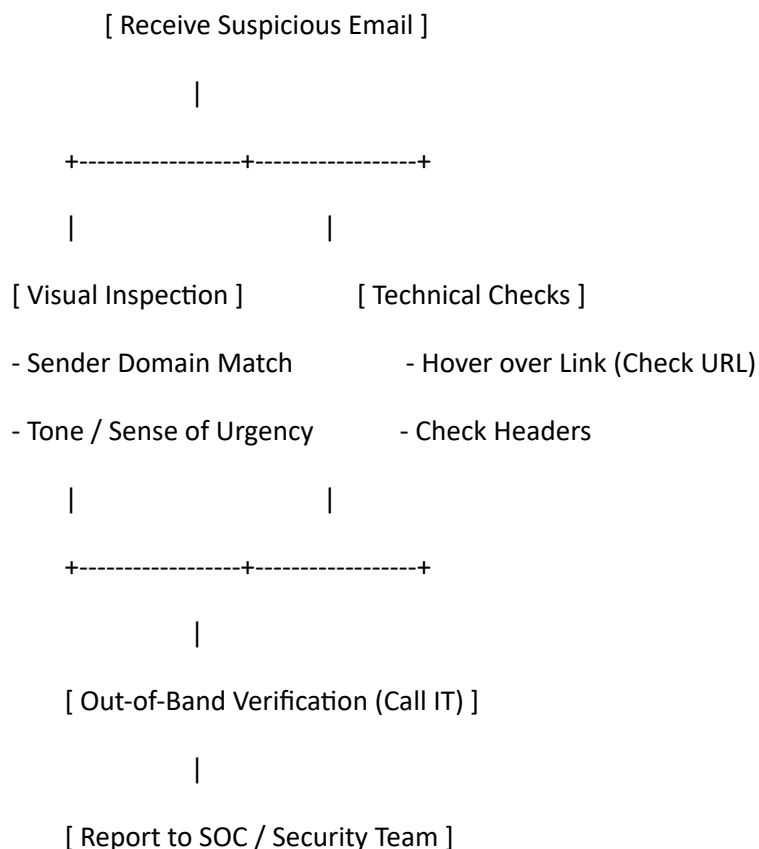
Question 3 (20 Marks)

1. Identification of the Attack Type

- **Attack Type: Spear-Phishing / Phishing (Credential Harvesting)**
- **Mechanism:** The attackers employ **Impersonation** (pretending to be the internal IT department) combined with **Urgency** (citing a "critical security update") to manipulate human emotion and deceive employees into surrendering sensitive corporate login credentials via a fake login link.

2. Countermeasures to Apply Before Responding

Employees must execute the following structured verification steps upon receiving suspect communications:



Pre-Response Actions:

1. **Inspect Header and Domain Authenticity:**
 - Verify that the sender address precisely matches the official domain (e.g., checking for subtle spoofing like admin@abc-technolog1es.com).
2. **Hover Over Links (URL Inspection):**
 - Position the mouse cursor over the link without clicking to view the actual destination URL. Ensure it points to an official corporate domain rather than an external credential-harvesting site.
3. **Out-of-Band Verification:**
 - Contact the internal IT Helpdesk via an established, trusted channel (such as an internal phone extension or messaging platform) to confirm whether a real security update was issued. Never reply directly to the email.
4. **Report via One-Click Incident Response:**
 - Use the corporate "Report Phishing" button or forward the email directly to security@abctechnologies.com.

3. Prevention Analysis: How Actions Prevent Credential Theft

Attack Vector	Action Taken	Prevention Mechanism
-----	-----	-----
Urgent Link	---> Out-of-Band Check	---> Validates legitimacy; halts interaction if fake.
Phishing Link	---> Hover / Domain Inspection	---> Prevents navigation to malicious forms.
Targeted Prompt	---> Multi-Factor Auth (MFA)	---> Renders intercepted credentials useless to attackers.

- **Breaking the Attack Chain:** Verifying the domain or verifying via an external channel prevents the user from navigating to the malicious login page, ensuring credentials are never entered.

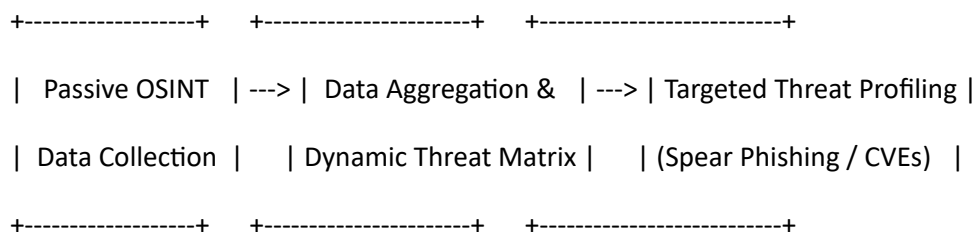
- **Mitigating Human Vulnerability:** Urgency creates panic, causing individuals to bypass standard logic. Mandating verification procedures counters psychological manipulation.
- **Defense-in-Depth Context (MFA Integration):** Even if an employee accidentally enters their password, implementing **Multi-Factor Authentication (MFA)** with hardware tokens or push notifications blocks unauthorized logins by requiring a second factor that the attacker does not possess.

. Identification of Publicly Available Information & Tool Selection

To gather comprehensive passive intelligence on **ABC Technologies** without directly interacting with their servers, an analyst must utilize Open-Source Intelligence (OSINT) tools across four distinct operational vectors:

- **Domain Registration Details:**
 - **Tool:** Whois command-line utility / **ICANN Lookup**
 - **Application:** Running whois abctechnologies.com queries global Regional Internet Registries (RIRs) such as ARIN, RIPE, or APNIC.
 - **Data Collected:** Domain creation/expiry dates, administrative and technical contact details, registered organizational address, and designated authoritative Name Servers (NS).
- **Employee Email Addresses:**
 - **Tool:** theHarvester / Hunter.io
 - **Application:** Executing theHarvester -d abctechnologies.com -b all scrapes engine search results (Google, Bing, DuckDuckGo) and public data repositories.
 - **Data Collected:** Active corporate email formats (e.g., first.last@abctechnologies.com), names of current employees, job roles, and exposed credentials from historic data breaches.
- **Technology Stack:**
 - **Tool:** BuiltWith / Wappalyzer
 - **Application:** Analyzing cached web responses, HTTP header signatures, and publicly indexed client-side scripts.
 - **Data Collected:** Web server software (e.g., Nginx 1.18, Apache), Content Management Systems (CMS like WordPress or Drupal), JavaScript libraries, cloud hosting providers (AWS/Azure), and active analytics or security plugins.
- **Publicly Exposed Subdomains:**
 - **Tool:** Sublist3r / crt.sh (Certificate Transparency Logs)
 - **Application:** Querying search engine dorks and public SSL/TLS Certificate Transparency (CT) log databases for *.abctechnologies.com.
 - **Data Collected:** Enumeration of subdomains including vpn.abctechnologies.com, dev-api.abctechnologies.com, mail.abctechnologies.com, and jira.abctechnologies.com.

2. Technical Explanation for Competitive Intelligence & Attack Mapping



Passive footprinting is crucial for both security assessments and competitive intelligence:

1. **Uncovering Weak Entry Points:** Subdomains containing prefixes like dev, test, stage, or old frequently run unpatched, legacy web application stacks with reduced security monitoring compared to primary production environments.
2. **Precision Social Engineering Profiling:** Identifying employee email structures combined with scraping professional platforms (e.g., LinkedIn) allows an attacker to build an organizational chart. This enables convincing, role-tailored Spear-Phishing or Business Email Compromise (BEC) attacks.
3. **Targeted Vulnerability Identification:** Identifying exact software versions (e.g., an outdated Apache version via BuiltWith) allows an analyst to cross-reference specific Common Vulnerabilities and Exposures (CVEs) and plan exploits without sending a single active port scan packet to the victim's firewalls.

Topic 2: DNS Zone Transfers

Question 2 (15 Marks)

1. Verification of Misconfigured Zone Transfers

A DNS Zone Transfer uses the **AXFR** protocol over TCP port 53 to replicate DNS records between primary and secondary DNS servers. To test if **ABC Technologies'** DNS server allows unauthorized zone transfers:

Command-Line Execution using dig:

1. Step 1: Identify the Authoritative Name Servers

Bash

```
dig NS abctechnologies.com +short
```

Expected Output:

Plaintext

```
ns1.abctechnologies.com.
```

```
ns2.abctechnologies.com.
```

1. Step 2: Request the Full Zone Transfer (AXFR)

Bash

```
dig @ns1.abctechnologies.com abctechnologies.com AXFR
```

Alternative Execution using nslookup:

Bash

```
nslookup
```

```
> server ns1.abctechnologies.com
```

```
> set type=any
```

```
> ls -d abctechnologies.com
```

2. Detailed Breakdown of Retrieved DNS Records

If the DNS server is improperly configured to answer AXFR requests from arbitrary client IPs, the entire internal and external network topology is exposed. The table below illustrates how each record type aids reconnaissance:

DNS Record Type	Example Output Record	Strategic Reconnaissance Value
A / AAAA	db-prod.abctechnologies.com. IN A 192.168.10.45	Maps subdomains to exact IPv4/IPv6 addresses, pinpointing high-value targets like database servers.
MX (Mail Exchanger)	abctechnologies.com. IN MX 10 mail.abctechnologies.com.	Identifies primary and backup mail gateways for email spoofing, interception, or mail server exploitation.
CNAME	storage.abctechnologies.com. IN CNAME abc-bucket.s3.amazonaws.com	Exposes aliases pointing to external cloud resources, enabling Subdomain Takeover attacks if the cloud asset is decommissioned.
PTR	45.10.168.192.in-addr.arpa. IN PTR db-prod.abctechnologies.com.	Provides reverse DNS resolution, mapping IP ranges directly to internal hostnames.
TXT	abctechnologies.com. IN TXT "v=spf1 include:_netblocks.google.com ~all"	Details domain verification tokens, SPF/DKIM policy configurations, and cloud provider integrations.
SOA (Start of Authority)	abctechnologies.com. IN SOA ns1... hostmaster...	Displays zone administrative contact emails, refresh rates, and master DNS server naming constructs.

3. Impact on Internal Infrastructure Discovery

- **Elimination of Guesswork:** Instead of brute-forcing subdomains with wordlists, an adversary instantly obtains an explicit inventory of every registered host (e.g., payroll.abctechnologies.com, vpn-internal.abctechnologies.com).
- **Network Structure Mapping:** Internal IP addresses exposed in A records reveal subnets, gateway locations, and IP segmentation strategies, laying out a clear roadmap for post-exploitation lateral movement.

Topic 3: Introduction to Social Engineering – Attacks & Countermeasures

Question 3 (20 Marks)

1. Attack Categorization and Psychological Triggers

- **Primary Attack Vector: Spear-Phishing / Credential Harvesting**
- **Psychological Mechanics Utilized:**
 - **Authority:** Attackers impersonate the internal IT Department to command compliance.
 - **Urgency & Fear:** The prompt forces immediate compliance under threat of system lockouts or missed "urgent security updates".
 - **Deception:** Utilizing look-alike domains or deceptive hyperlink texts to lead victims to a fake authentication portal.

2. Comprehensive Employee Countermeasures (Pre-Response)

Employees should follow a multi-step checklist prior to clicking links or entering credentials:

[Incoming Email Received]

